

10_SYSTEM AND NETWORK SECURITY

Security is not just “a product” (for example a firewall). It is rather a “process”, which needs to be managed properly.

Nothing is 100% secure (“The three golden rules for ensuring computer security: do not own a computer; do not power it on; and do not use it.”).

The security of a system is equivalent to the security of its less secure component (rule of the weakest link).

Security by obscurity never works: pensare di garantire la sicurezza di un sistema non dicendo come funziona non funziona (basta fare reverse engineering).

Cryptography is a powerful tool but it is not enough.

L’anello più debole di un sistema è l’utente. Do not rely on users!

Quando è che un network/system è sicuro?

Operating Systems: Internals and Design Principles.

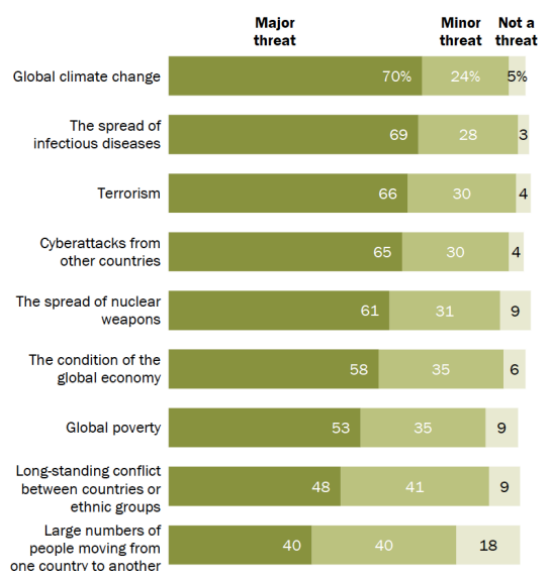
Si basa sull’arte della guerra:

“The art of war teaches us to rely not on the likelihood of the enemy’s not coming, but on our own readiness to receive him; not on the chance of his not attacking, but rather on the fact that we have made our position unassailable.”

Indagine sulla percezione del cybercrime (2020):

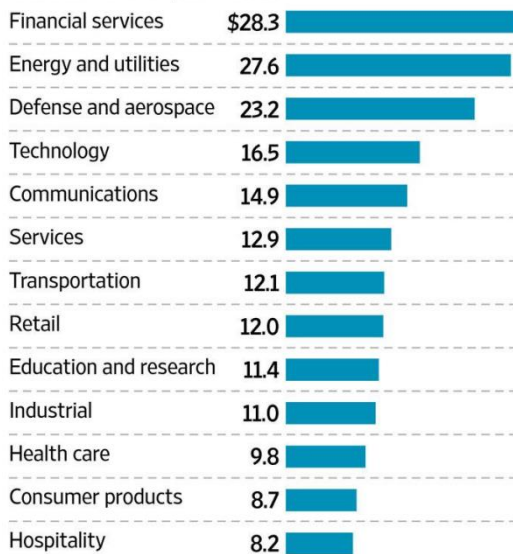
Across 14 countries polled, climate change and infectious diseases top list of global threats

Median % who say the following are a ___ to their country



Cybercrime Costs

The financial toll of cyberattacks in selected U.S. industries in 2015, in millions



Source: Ponemon Institute/Hewlett Packard survey of 58 U.S. organizations, August 2015 THE WALL STREET JOURNAL.

Cyber Security Statistics in 2019

Almost half of all companies have over 1,000 sensitive pieces of information that are not protected



The biggest cost from a cyber attack is productivity



● Attack Cost 23% ● Productivity Cost 77%

Attacks on healthcare are expected to increase by

400%

in 2020



The cost of cyber crime is expected to exceed

\$6 Trillion

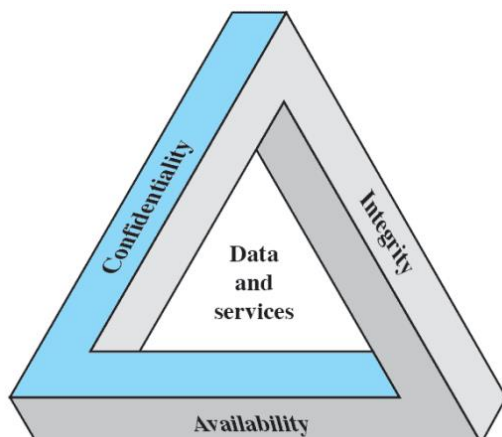
Annually by 2021



The NIST Computer Security Handbook defines **computer security**: protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability and confidentiality of information system resources (includes hardware, software, firmware, information/data, and telecommunications).

CIA Triad: obiettivi della sicurezza:

- Confidentiality, a loss of confidentiality is the unauthorized disclosure of information.
- Integrity, a loss of integrity is the unauthorized modification or destruction of information
- Availability, a loss of availability is the disruption of access to or use of information or an information system



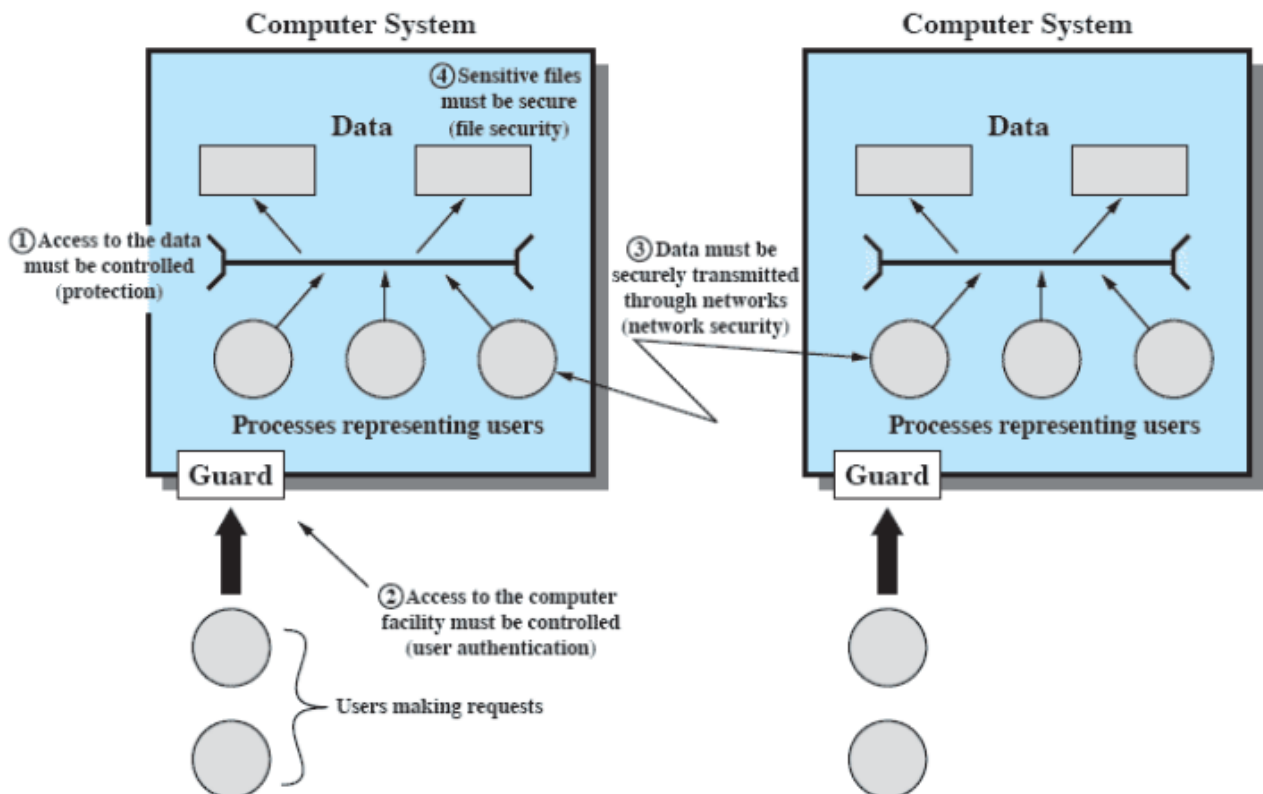
Key Objectives of Computer Security:

- **Confidentiality:**
 - **data confidentiality** assures that private or confidential information is not made available or disclosed to unauthorized individuals
 - **privacy** assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed
- **Integrity:**
 - **data integrity** assures that information and programs are changed only in a specified and authorized manner (ad esempio solo il professore può cambiare il voto di un esame).
 - **system integrity** assures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system
- **Availability:** assures that systems work promptly and service is not denied to authorized users

Additional Concepts:

- **Authenticity:** the property of being genuine and being able to be verified and trusted; confidence in the validity of a transmission, a message, or message originator.
Verifying that users are who they say they are and that each input arriving at the system came from a trusted source.
- **Accountability:** the security goal that generates the requirement for actions of an entity to be traced uniquely to that entity.
We must be able to trace a security breach to a responsible party.
Systems must keep records of their activities to permit later forensic analysis to trace security breaches or to aid in transaction disputes.

Scopo del system security:



Examples of Threats:

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service.		
Software	Programs are deleted, denying access to users.	An unauthorized copy of software is made.	A working program is modified, either to cause it to fail during execution or to cause it to do some unintended task.
Data	Files are deleted, denying access to users.	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data.	Existing files are modified or new files are fabricated.
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable.	Messages are read. The traffic pattern of messages is observed.	Messages are modified, delayed, reordered, or duplicated. False messages are fabricated.

10.1 CYBER ATTACKS

Ci sono due tipi di attacchi:

- **Attacchi passivi:** the attacker can only read any information (Tempest (signal intelligence), Packet Sniffing)
Attempts to learn or make use of information from the system but does not affect system resources.

Are in the nature of eavesdropping on, or monitoring of, transmissions.

Goal of the attacker is to obtain information that is being transmitted.

Difficult to detect because they do not involve any alteration of the data, is feasible to prevent the success of these attacks by means of encryption.

Emphasis in dealing with passive attacks is on prevention rather than detection.

- **Attacchi attivi:** the attacker can read, modify, generate, destroy any information.
Involve some modification of the data stream or the creation of a false stream.

There are four categories:

- **Replay**, involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect
- **Masquerade**, takes place when one entity pretends to be a different entity
- **Modification of messages**, some portion of a legitimate message is altered, or that messages are delayed or reordered, to produce an unauthorized effect
- **Denial of service**, prevents or inhibits the normal use or management of communications facilities. Disruption of an entire network either by disabling the network or by overloading it with messages so as to degrade performance

Intruder Patterns of Behavior, **Hackers:**

- Traditionally those who hack do so for the thrill of it or for status.
- Attackers often look for targets of opportunity and then share the information with others.
- Benign intruders consume resources and may slow performance for legitimate users.
- Intrusion detection systems (IDSs) and intrusion prevention systems (IPSs) are designed to counter this type of hacker threat.
- Computer emergency response teams (CERTs) are cooperative ventures who collect information about system vulnerabilities and disseminate it to systems managers.

1. Select the target using IP lookup tools such as NSLookup, Dig, and others.
2. Map network for accessible services using tools such as NMAP.
3. Identify potentially vulnerable services
4. Brute force (guess) password.
5. Install remote administration tool
6. Wait for administrator to log on and capture his password.
7. Use that password to access remainder of network.

Hacker

Intruder Patterns of Behavior, **Insider Attacks:**

- Among the most difficult to detect and prevent
- Can be motivated by revenge or simply a feeling of entitlement
- Employees already have access to and knowledge of the structure and content of corporate databases

1. Create network accounts for themselves and their friends.
2. Access accounts and applications they wouldn't normally use for their daily jobs.
3. E-mail former and prospective employers.
4. Conduct furtive instant-messaging chats.
5. Visit Web sites that cater to disgruntled employees, such as fdcompany.com.
6. Perform large downloads and file copying.
7. Access the network during off hours.

Internal Threat

Intruder Patterns of Behavior, **Criminal Enterprise:**

- Organized groups of hackers
- They meet in underground forums to trade tips and data and coordinate attacks
- Usually have specific targets, or at least classes of targets in mind. A common target is a credit card file at an e-commerce server
- Quick in and quick out attacks

1. Act quickly and precisely to make their activities harder to detect.
2. Exploit perimeter through vulnerable ports.
3. Use Trojan horses (hidden software) to leave backdoors for reentry.
4. Use sniffers to capture passwords.
5. Do not stick around until noticed.
6. Make few or no mistakes.

Criminal Enterprise

Intruder Patterns of Behavior, **Advanced Persistent Threat**:

- Organized groups of hackers, state sponsored
- They are composed by skilled individuals (not only hackers)
- They target Critical Infrastructure in order to sabotage them or exfiltrate sensitive information
- They perform complex and continuous attacks until they reach their goal
- They stay hidden inside the target organization

- 1) Reconnaissance
- 2) Weaponization
- 3) Delivery
- 4) Exploitation
- 5) Installation
- 6) Contacting Command and Control (C&C) (C2) server
- 7) Action on Objectives
- 8) Conceal Activity

Advanced Persistent Threat

Malware: general term for any malicious software. Software designed to cause damage to or use up the resources of a target computer, frequently concealed within or masquerades as legitimate software. In some cases it spreads itself to other computers via e-mail or infected discs.

Terminology of Malicious Programs (Typi di Malware):

Name	Description
Virus	Malware that, when executed, tries to replicate itself into other executable code; when it succeeds the code is said to be infected. When the infected code is executed, the virus also executes.
Worm	A computer program that can run independently and can propagate a complete working version of itself onto other hosts on a network.
Logic bomb	A program inserted into software by an intruder. A logic bomb lies dormant until a predefined condition is met; the program then triggers an unauthorized act.
Trojan horse	A computer program that appears to have a useful function, but also has a hidden and potentially malicious function that evades security mechanisms, sometimes by exploiting legitimate authorizations of a system entity that invokes the Trojan horse program.
Backdoor (trapdoor)	Any mechanisms that bypasses a normal security check; it may allow unauthorized access to functionality.
Platform independent code	Software (e.g., script, macro, or other portable instruction) that can be shipped unchanged to a heterogeneous collection of platforms and execute with identical semantics.
Exploits	Code specific to a single vulnerability or set of vulnerabilities.
Downloaders	Program that installs other items on a machine that is under attack. Usually, a downloader is sent in an e-mail.
Auto-rooter	Malicious hacker tools used to break into new machines remotely.
Kit (virus generator)	Set of tools for generating new viruses automatically.
Spammer programs	Used to send large volumes of unwanted e-mail.
Flooders	Used to attack networked computer systems with a large volume of traffic to carry out a denial-of-service (DoS) attack.
Keyloggers	Captures keystrokes on a compromised system.
Rootkit	Set of hacker tools used after attacker has broken into a computer system and gained root-level access.
Zombie, bot	Program activated on an infected machine that is activated to launch attacks on other machines.
Spyware	Software that collects information from a computer and transmits it to another system.
Adware	Advertising that is integrated into software. It can result in pop-up ads or redirection of a browser to a commercial site.

Backdoor (trapdoor): a secret entry point into a program that allows someone to gain access without going through the usual security access procedures.

Maintenance hook: a backdoor that programmers use to debug and test programs.

Backdoors become threats when unscrupulous programmers use them to gain unauthorized access. It is difficult to implement operating system controls for backdoors.

Trojan horse: useful, or apparently useful, program or command procedure that contains hidden code that, when invoked, performs some unwanted or harmful function.

Ci sono 3 modelli di cavalli di troia:

- continuing to perform the function of the original program and additionally performing a separate malicious activity
- continuing to perform the function of the original program but modifying the function to perform malicious activity or to disguise other malicious activity
- performing a malicious function that completely replaces the function of the original program

Platform independent code: programs that can be shipped unchanged to a heterogeneous collection of platforms and execute with identical semantics.

Transmitted from a remote system to a local system and then executed on the local system without the user's explicit instruction. Often acts as a mechanism for a virus, worm, or Trojan horse to be transmitted to the user's workstation.

Takes advantages of vulnerabilities.

Virus: software that "infects" other programs by modifying them.

Carries instructional code to self duplicate, becomes embedded in a program on a computer. When the infected computer comes into contact with an uninfected piece of software, a fresh copy of the virus passes into the new program. Infection can be spread by swapping disks from computer to computer or through a network.

Un computer virus è composto da 3 parti:

- infection mechanism
- trigger
- payload

Un virus può infettare boot sector, file e/o macro.

Multiple-Threat Malware: infects in multiple ways, typically the multipartite virus is capable of infecting multiple types of files.

A blended attack uses multiple methods of infection or transmission to maximize the speed of contagion and the severity of the attack.

Rootkit: set of programs installed on a system to maintain administrator (or root) access to that system. Root access provides access to all the functions and services of the operating system. The rootkit alters the host's standard functionality in a malicious and stealthy way (with root access an attacker has complete control of the system and can add or change programs and files, monitor processes, send and receive network traffic, and get backdoor access on demand). A rootkit hides by subverting the mechanisms that monitor and report on the processes, files, and registries on a computer.

Rootkits can be classified based on whether they can survive a reboot and execution mode.

Un rootkit può essere:

- Persistent, activates each time the system boots.
- Memory based, has no persistent code and therefore cannot survive a reboot.
- User mode, intercepts calls to APIs and modifies returned results.
- Kernel mode, can intercept calls to native APIs in kernel mode. Can hide the presence of a malware process by removing it from the kernel's list of active processes.

10.2 BUFFER OVERFLOW

Buffer overflow: a very common attack mechanism. Prevention techniques are known, but it is still of major concern due to legacy of widely deployed buggy and continued careless programming techniques.

It is caused by programming error. Allows more data to be stored than capacity available in a fixed sized buffer. Buffer can be on stack, heap, global data.

Consists of overwriting adjacent memory location (corruption of program data, unexpected transfer of control, memory access violation, execution of code chosen by attacker).

To exploit a buffer overflow an attacker must identify a buffer overflow vulnerability in some program (inspection, tracing execution, fuzzing tools) and understand how buffer is stored in memory and determine potential for corruption.

The program stack (function stack, runtime stack) holds stack frames (activation records) for each function that is invoked.

Very common mechanism for high-level language implementation, so has special CPU support (Stack pointer register: ESP; Frame pointer register: EBP; push and pop machine instructions).

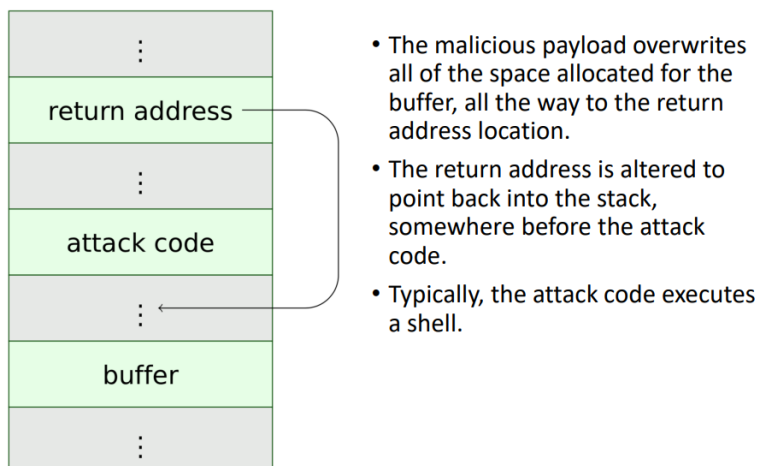
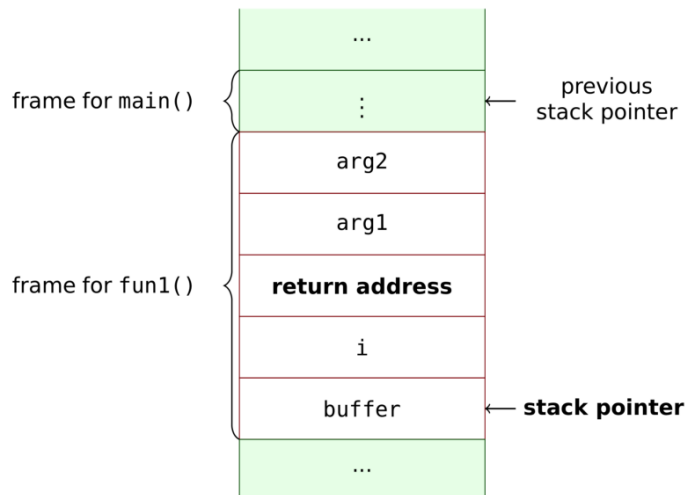
Parameters may be passed to the function body on the stack or in registers; the precise mechanism is called the calling convention.

Local variables are allocated space on the stack.

A frame pointer may be used to help locate arguments and local variables.

es.

```
void fun1(char arg1, int arg2) {  
    int i;  
    char buffer[5];  
    buffer[0] = (char)i;  
}  
void main() {  
    fun1('a', 77);  
}
```



- The malicious payload overwrites all of the space allocated for the buffer, all the way to the return address location.
- The return address is altered to point back into the stack, somewhere before the attack code.
- Typically, the attack code executes a shell.

All the attacker needs to do is stick a program in the buffer or environment. Attacker controls what goes in the buffer.

For instance, the payload starts a command shell from which the attacker can control the compromised machine (shellcode).

es.

```
void interact_with_user(char* pwd) {
    int authorized = check_auth(pwd); // 1 if right password provided
                                       // 0 otherwise

    char buf[256];
    printf("Enter your data: ");
    gets(buf);
    if (authorized) store_input_data(buf);
    else printf("Denied!");
}

int main(int argc, char** argv) {
    if (argc == 2) interact_with_user(argv[1]);
    return 0;
}
```

There are two vulnerabilities: I can set authorized without knowing the password; I can change the return pointer (execute code in memory or in buf).

Se io vado a scrivere 261 byte (256 per riempire il buf + 4 per int authorized = 260) in buf alloraandrò a modificare il return address.

Low-level languages manipulate memory directly. Advantage: efficient, precise. Disadvantage: easy to violate data abstractions, arbitrary access to memory, pointers and pointer arithmetic, mistakes violate memory safety.

A programming language or analysis tool is said to enforce memory safety if it ensures that reads and writes stay within clearly defined memory areas, belonging to different parts of the program. Memory areas are often delineated with types and a typing discipline.

To stop the attacks: code more carefully! The best defense is proper bounds checking, sometimes it is not obvious how to do it (programmers are bound to forget it).

None of the existing countermeasures fully stop the problem of buffer overflows.

Are there any system defenses that can help?

Protection from stack buffer overflows can be broadly classified into two categories:

- **Compile-time defenses:** aims to harden programs to resist attacks in new programs. Aim to prevent or detect buffer overflows by instrumenting programs when they are compiled. Choice of Programming Language, Safe Coding Techniques, Language Extensions and Use of Safe Libraries, Stack Protection Mechanisms.
- **Stack protection mechanisms:** aims to detect and abort attacks in existing programs

Many C library functions do not check input size

- gets is inherently unsafe and was recently removed
- strcpy is safe as long as you're an educated C programmer 😊
 - If you pass a string of unknown length to it, or some data chunk that does not end with \0, you clearly made a mistake
 - Similar considerations apply for instance to strcat

Variants of such functions explicitly check input size

- strncpy is often suggested as replacement for strcpy...
 - However, did you know that no \0 character is appended at the end of destination if source is longer than the specified number of bytes?
 - Things like strncpy and strncat are better still!
- snprintf is typically better than sprintf (at least in C99)
- fgets is surely better than gets, but consider getline as well

To stop the attacks we can use a variety of tricks in combination: NX bit, Canaries, ASLR.

Compiler-level technique:

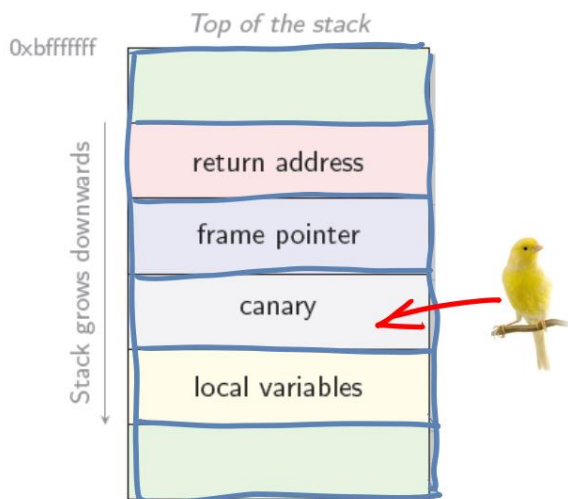
Canaries: the goal is to make sure we detect overflow of return address. The functions' prologues insert a canary on the stack. The canary is a 32-bit value inserted between the return address and local variables.

Tipi di Canaries:

- Terminator 2
- Random 3
- Random XOR

The epilogue checks if the canary has been altered.

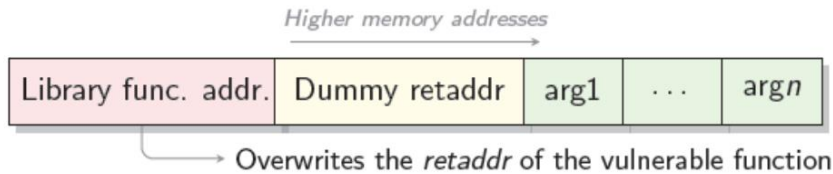
Drawback: requires recompilation.



System-level techniques:

Idea: separate executable memory locations from writable ones, a memory page cannot be both writable and executable at the same time (**Data Execution Prevention, DEP**).

Bypassing W⊕X: return into libc. Three assumptions: We can manipulate a code pointer (e.g., return address), the stack is writable, we know the address of a “suitable” library function (e.g., system()) can spawn a shell to run a command).



Bots (Zombie, Drone): a program that secretly takes over another Internet-attached computer and then uses that computer to launch attacks that are difficult to trace to the bot’s creator.

Typically planted on hundreds or thousands of computers belonging to unsuspecting third parties.

Collection of bots acting in a coordinated manner is a **botnet**.

A botnet exhibits three characteristics:

- the bot functionality
- a remote control facility
- a spreading mechanism to propagate the bots and construct the botnet

The first step in a botnet attack is for the attacker to infect a number of machines with bot software that will ultimately be used to carry out the attack. Essential ingredients:

- software that can carry out the attack
- a vulnerability in a large number of systems
- strategy for locating and identifying vulnerable machines (a process known as scanning or fingerprinting)

In the scanning process the attacker first seeks out a number of vulnerable machines and infects them. The bot software in the infected machines repeats the same scanning process until a large distributed network of infected machines is created.

Scanning strategies: Random, Hit list, Topological, Local subnet.

Uses of Bots:

- Distributed denial-of-service (DDoS) attacks, causes a loss of service to users
- Spamming, sending massive amounts of bulk e-mail (spam)
- Sniffing traffic, a packet sniffer is used to retrieve sensitive information like user names and passwords
- Keylogging, captures keystrokes
- Spreading new malware, botnets are used to spread new bots
- Installing advertisement add-ons and browser helper objects (BHOs), set up a fake Web site and negotiate a deal with hosting companies that pay for clicks on ads
- Attacking Internet Relay chat (IRC) chat networks, victim is flooded with requests, bringing down the IRC network; similar to a DDoS attack
- Manipulating online polls/games, every bot has a distinct IP address so it appears to be a real person

Denial of Service (DoS): an action that prevents or impairs the authorized use of networks, systems, or applications by exhausting resources such as central processing units (CPU), memory, bandwidth, and disk space.

Attacks network bandwidth, system resources, application resources.

Classic Denial of Service Attacks can use simple flooding ping, from higher capacity link to lower, causing loss of traffic, source of flood traffic easily identified.

Classified based on network protocol used, there are three types of Flooding Attacks:

- ICMP Flood, uses ICMP packets, eg echo request; typically allowed through, some required
- UDP Flood, alternative uses UDP packets to some port
- TCP SYN Flood, use TCP SYN (connection request) packets; but for volume attack.

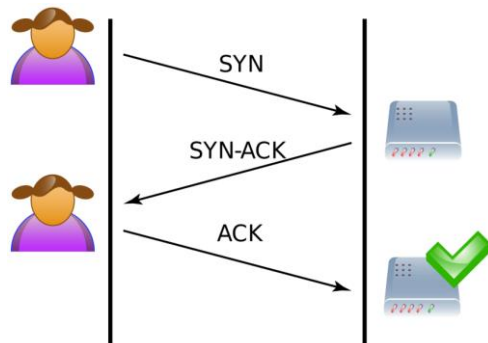
SYN Spoofing Attack: attacker often uses either random source addresses or that of an overloaded server, to block return of (most) reset packets

Has much lower traffic volume, attacker can be on a much lower capacity link.

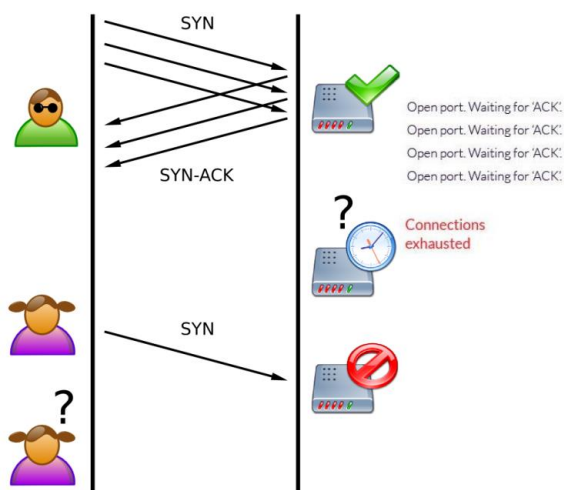
Source Address Spoofing: use forged source addresses, given sufficient privilege to “raw sockets”, easy to create.

Generate large volumes of packets, directed at target with different, random, source addresses. Cause same congestion, responses are scattered across Internet, real source is much harder to identify.

TCP Connection Handshake:

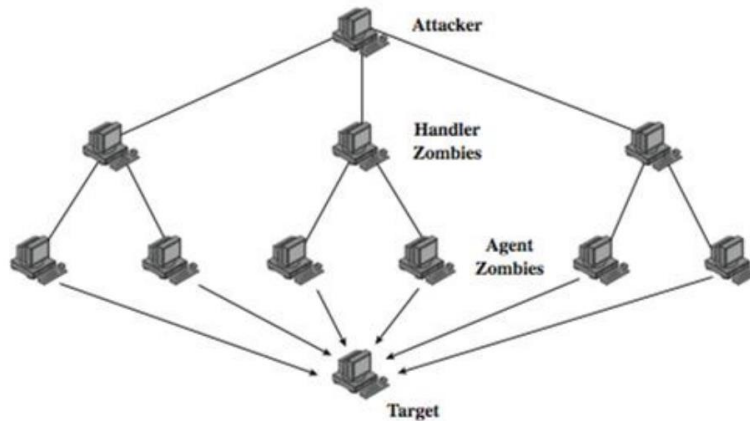


SYN Spoofing Attack:



Distributed Denial of Service Attacks: have limited volume if single source used. Multiple systems allow much higher traffic volumes to form a Distributed Denial of Service (DDoS) Attack. Often compromised PC's /workstations, zombies with backdoor programs installed, forming a botnet.

DDoS Control Hierarchy:



DoS Attack Defenses:

- High traffic volumes may be legitimate, result of high publicity, (e.g. “slash-dotted”), or result to a very popular site, (e.g. Olympics etc)
- Legitimate traffic created by an attacker
- Three lines of defense against (D)DoS: attack prevention and preemption; attack detection and filtering; attack source traceback and identification.

Attack Prevention:

- block spoofed source addresses, on routers as close to source as possible. Still far too rarely implemented
- rate controls in upstream distribution nets, on specific packets types (e.g. some ICMP, some UDP, TCP/SYN)
- use modified TCP connection handling, use SYN cookies when table full, or selective or random drop when table full
- block IP directed broadcasts
- block suspicious services & combinations
- manage application attacks with “puzzles” to distinguish legitimate human requests
- good general system security practices
- use mirrored and replicated servers when high-performance and reliability required

Responding to Attacks:

- need good incident response plan, with contacts for ISP, needed to impose traffic filtering upstream, details of response process
- have standard filters
- ideally have network monitors and IDS, to detect and notify abnormal traffic pattern.
- identify type of attack, capture and analyze packets, design filters to block attack traffic upstream, or identify and correct system/application bug
- have ISP trace packet flow back to source, may be difficult and time consuming, necessary if legal action desired
- implement contingency plan
- update incident response plan

10.3 PROTECTION TECHNIQUES

Cryptographic Tools: cryptographic algorithms are important element in security services. Review various types of elements: symmetric encryption, public-key (asymmetric) encryption, digital signatures and key management, secure hash functions.

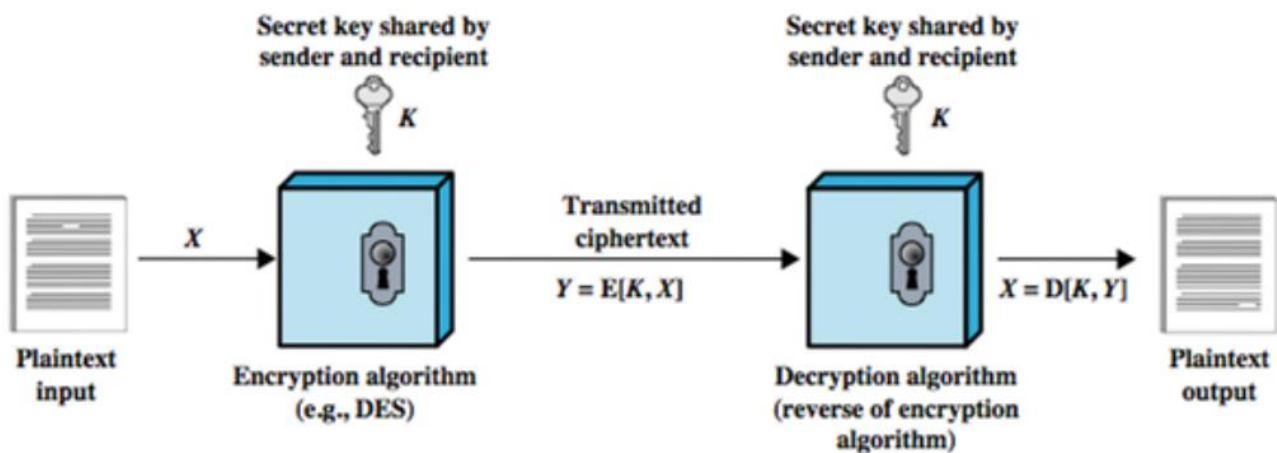
Random numbers have a range of uses. Requirement:

- randomness, based on statistical tests for uniform distribution and independence.
- unpredictability, successive values not related to previous. Clearly true for truly random numbers, but more commonly use generator.

Often use algorithmic technique to create pseudorandom numbers, which satisfy statistical randomness tests, but likely to be predictable.

True random number generators use a nondeterministic source (e.g. radiation, gas discharge, leaky capacitors), increasingly provided on modern processors.

Symmetric Encryption:

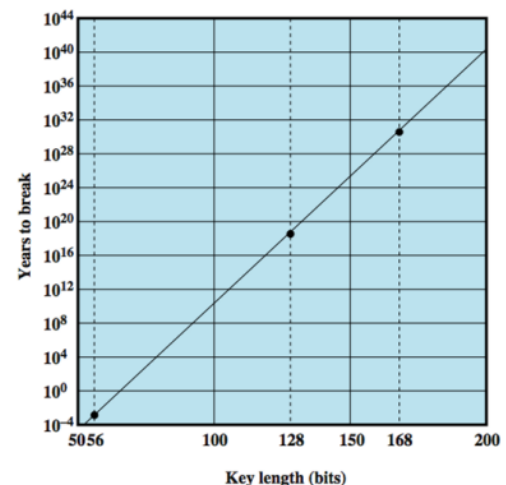


Attacking Symmetric Encryption:

- cryptanalysis, rely on nature of the algorithm, plus some knowledge of plaintext characteristics, even some sample plaintext-ciphertext pairs, exploits characteristics of algorithm to deduce specific plaintext or key
- brute-force attack, try all possible keys on some ciphertext until get an intelligible translation into plaintext

Exhaustive Key Search:

Key Size (bits)	Number of Alternative Keys	Time Required at 1 Decryption/ μ s	Time Required at 10^6 Decryptions/ μ s
32	$2^{32} = 4.3 \times 10^9$	$2^{31} \mu s = 35.8$ minutes	2.15 milliseconds
56	$2^{56} = 7.2 \times 10^{16}$	$2^{55} \mu s = 1142$ years	10.01 hours
128	$2^{128} = 3.4 \times 10^{38}$	$2^{127} \mu s = 5.4 \times 10^{24}$ years	5.4×10^{18} years
168	$2^{168} = 3.7 \times 10^{50}$	$2^{167} \mu s = 5.9 \times 10^{36}$ years	5.9×10^{30} years
26 characters (permutation)	$26! = 4 \times 10^{26}$	$2 \times 10^{26} \mu s = 6.4 \times 10^{12}$ years	6.4×10^6 years



Symmetric Encryption Algorithms:

	DES	Triple DES	AES
Plaintext block size (bits)	64	64	128
Ciphertext block size (bits)	64	64	128
Key size (bits)	56	112 or 168	128, 192, or 256

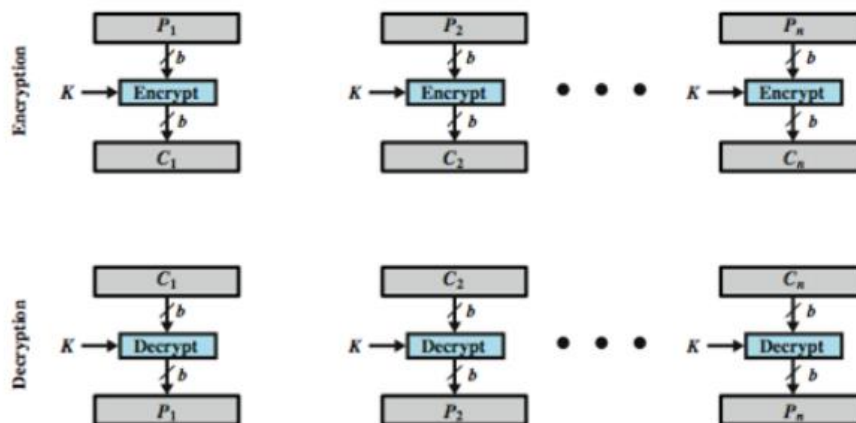
DES = Data Encryption Standard
 AES = Advanced Encryption Standard

Data Encryption Standard (DES): is unfortunately one of the most widely used encryption schemes. Uses 64 bit plaintext block and 56 bit key to produce a 64 bit ciphertext block. Concerns about algorithm & use of 56-bit key.

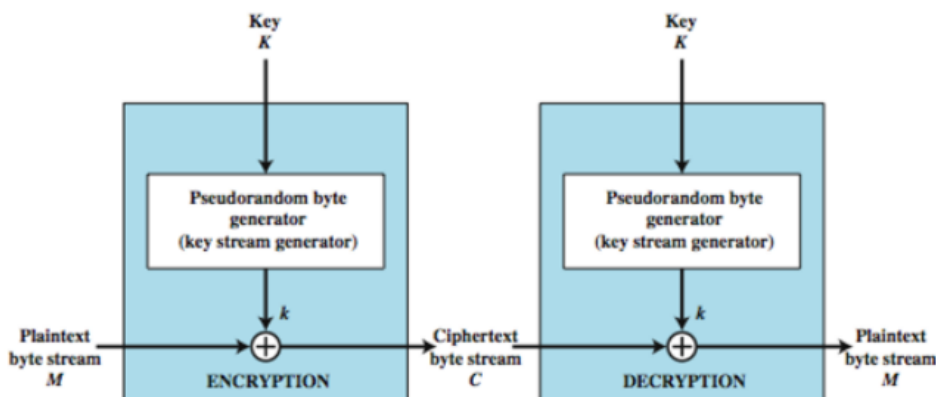
Triple-DES: repeats basic DES algorithm three times, using either two or three unique keys. Much more secure but also much slower.

Advanced Encryption Standard (AES): symmetric block cipher, uses 128 bit data & 128/192/256 bit keys.

Block vs. Stream ciphers:

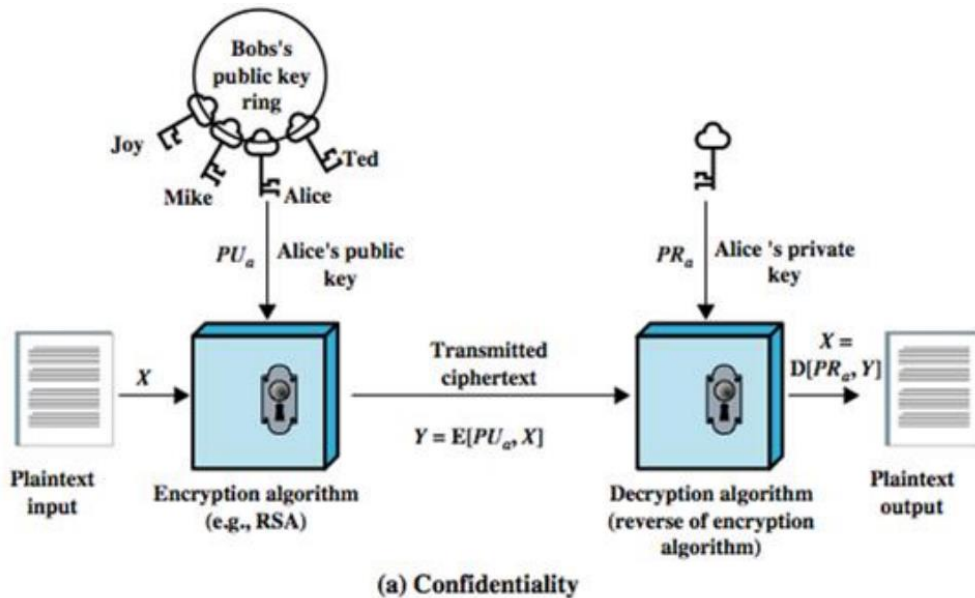


(a) Block cipher encryption (electronic codebook mode)



(b) Stream encryption

Public Key Encryption:



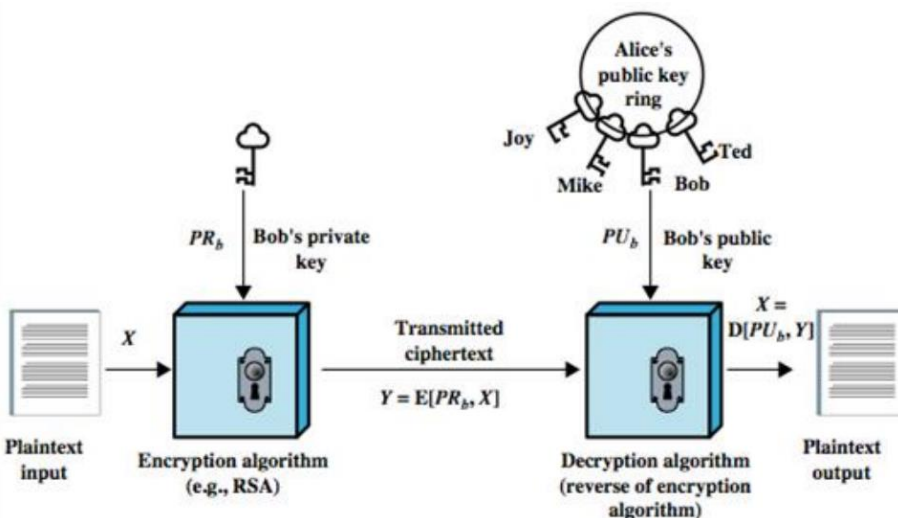
Public Key Requirements:

- computationally easy to create key pairs
- computationally easy for sender knowing public key to encrypt messages
- computationally easy for receiver knowing private key to decrypt ciphertext
- computationally infeasible for opponent to determine private key from public key
- computationally infeasible for opponent to otherwise recover original message
- useful if either key can be used for each role

Public Key Algorithms più famosi:

- RSA (Rivest, Shamir, Adleman): only widely accepted public-key encryption alg, given tech advances need 1024+ bit keys
 - Diffie-Hellman key exchange algorithm: only allows exchange of a secret key
 - Digital Signature Standard (DSS): provides only a digital signature function with SHA-1
 - Elliptic curve cryptography (ECC): new, security like RSA, but with much smaller keys.
- Homomorphic cryptography (HE), allows elaboration of encrypted data.

Public Key Authentication:

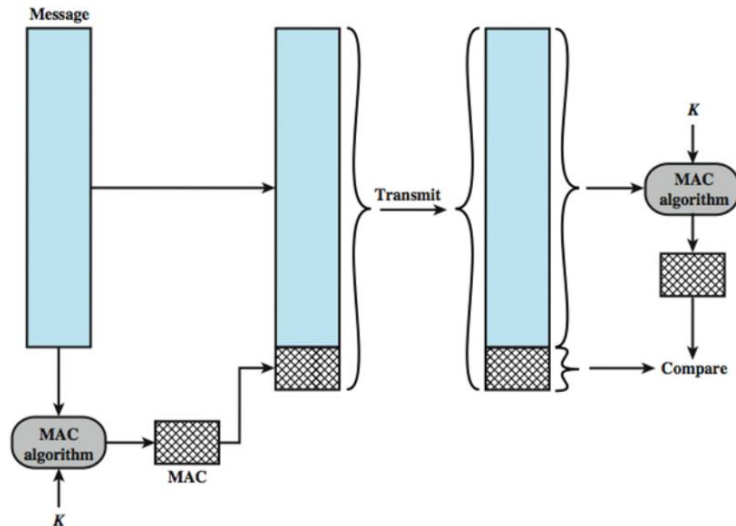


Message authentication:

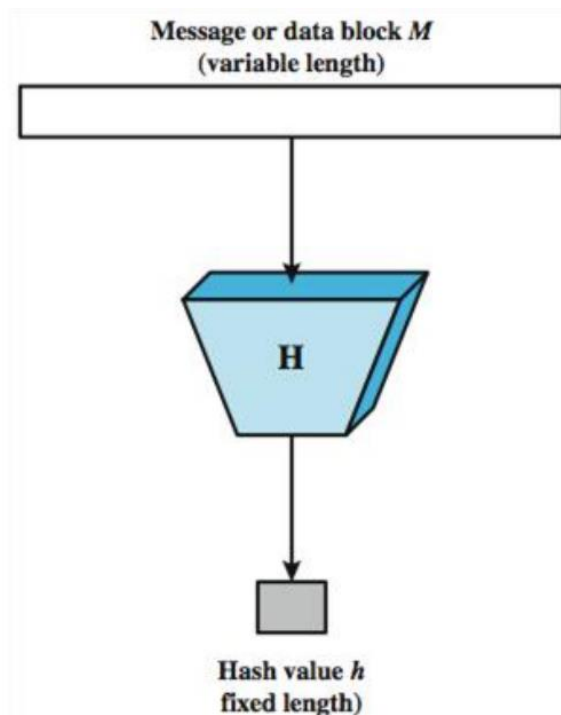
Protects against active attacks. Verifies received message is authentic (contents unaltered, from authentic source, timely and in correct sequence)

Can use conventional encryption (only sender and receiver have key needed) or separate authentication mechanisms (append authentication tag to cleartext message).

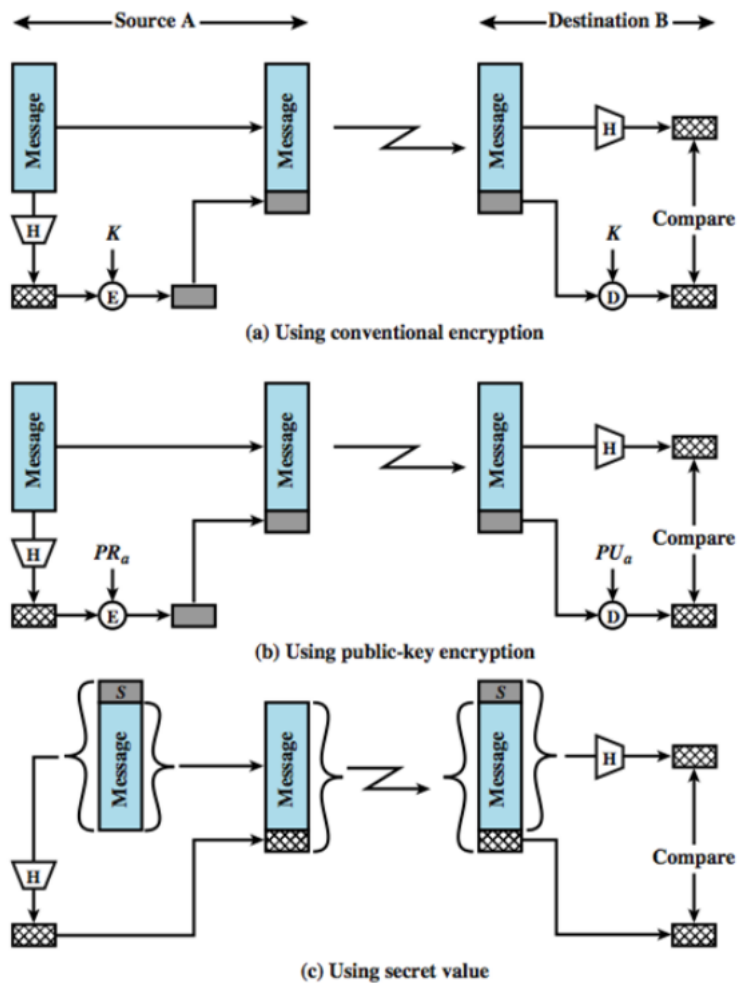
Message Authentication Codes:



Secure Hash Functions:



Message Authentication:



Hash Function Requirements:

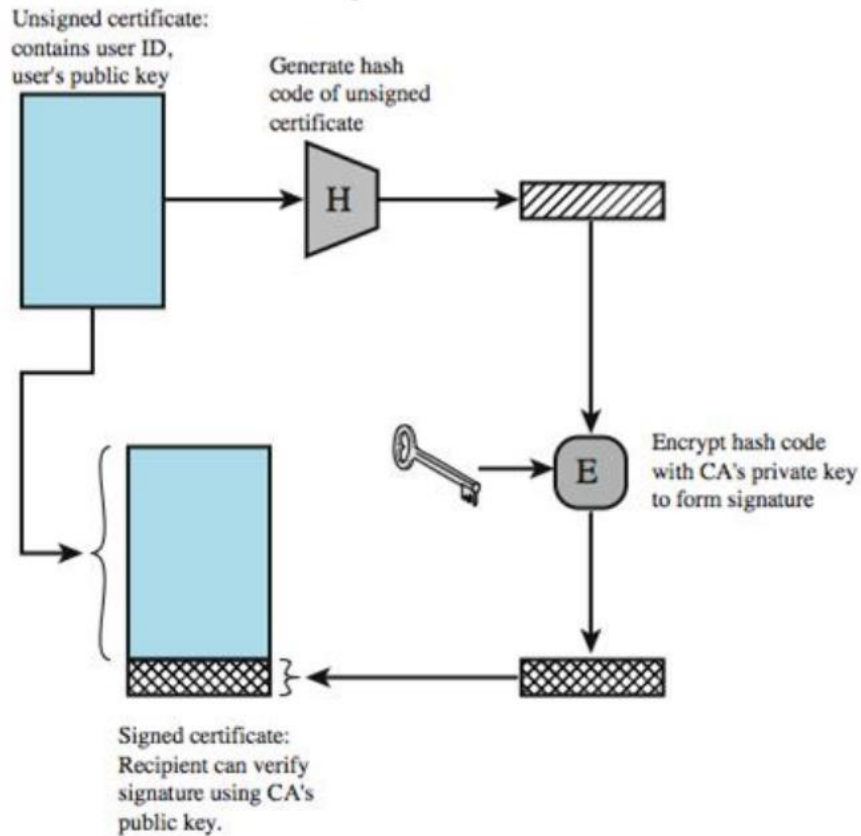
- applied to any size data
- H produces a fixed-length output
- $H(x)$ is relatively easy to compute for any given x
- one-way property: computationally infeasible to find x such that $H(x) = h$
- weak collision resistance: given x , computationally infeasible to find $y \neq x$ such that $H(y) = H(x)$
- strong collision resistance: computationally infeasible to find any pair (x, y) such that $H(x) = H(y)$

There are two attack approaches:

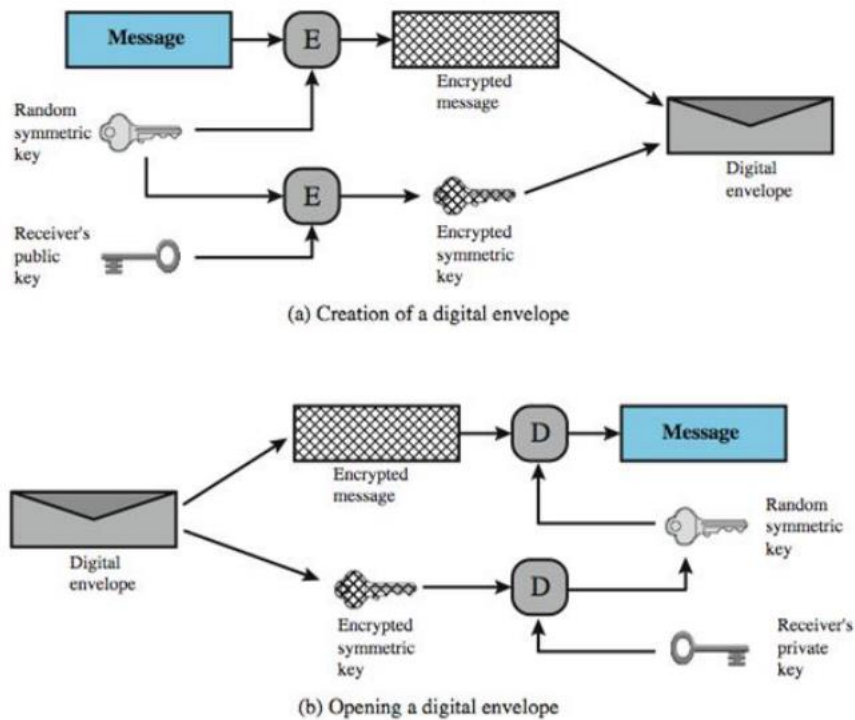
- cryptanalysis: exploit logical weakness in alg
- brute-force attack: trial many inputs, strength proportional to size of hash code

SHA most widely used hash algorithm (SHA-1 gives 160-bit hash; more recent SHA-256, SHA-384, SHA-512 provide improved size and security).

Public Key Certificates:



Digital Envelopes:



Common to encrypt transmitted data. Much less common for stored data, which can be copied, backed up, recovered.

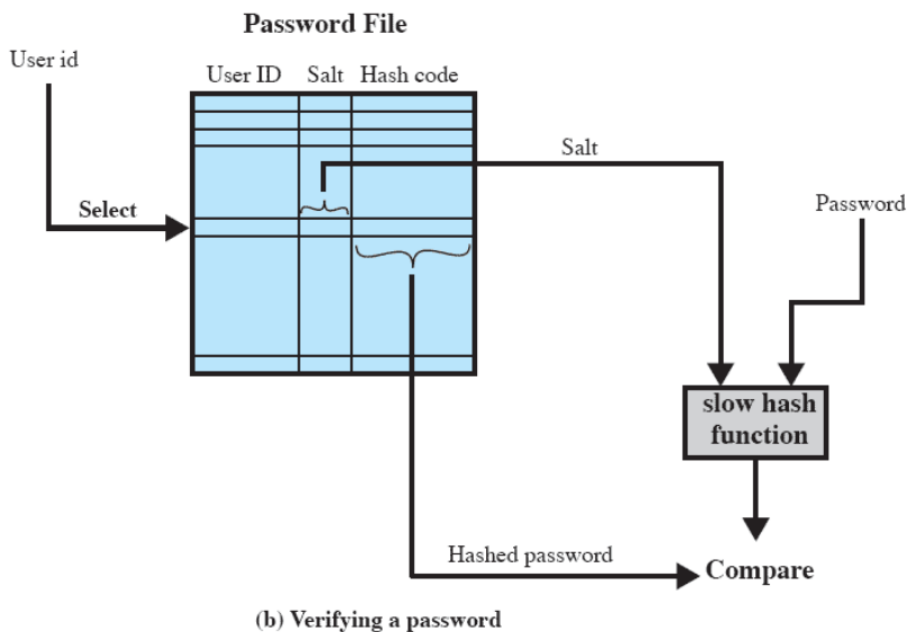
- back-end appliance
- library based tape encryption
- background laptop/PC data encryption

Password-Based Authentication: a widely used line of defense against intruders is the password system. The password serves to authenticate the ID of the individual logging on to the system. The ID provides security by determining whether the user is authorized to gain access to a system, by determining the privileges accorded to the user and by discretionary access control.

[illegible]

(a) Loading a new password

UNIX Password Scheme:



Salt serves three purposes:

- prevents duplicate passwords from being visible in the password file (even if two users choose the same password, the passwords will be assigned different salt values)
- greatly increases the difficulty of offline dictionary attacks
- it becomes nearly impossible to find out whether a person with passwords on two or more systems has used the same password on all of them

There are two threats to the UNIX password scheme:

- a user can gain access on a machine using a guest account
- Password cracker: password guessing program

If an opponent is able to obtain a copy of the password file, a cracker program can be run on another machine at leisure. This enables the opponent to run through millions of possible passwords in a reasonable period.

UNIX Implementations:

most implementations have relied on a password scheme where each user selects a password of up to eight printable characters in length which is converted into a 56-bit value that serves as the key input to an encryption routine.

The hash routine, known as crypt(3) is based on DES. The crypt(3) routine is designed to discourage guessing attacks. Software implementations of DES are slow compared to hardware versions.

The recommended hash function for many UNIX systems, including Linux, Solaris, and FreeBSD is based on the MD5 secure hash algorithm.

The most secure version of the UNIX hash/salt scheme was developed for OpenBSD and uses a hash function (Bcrypt) based on the Blowfish symmetric block cipher.

Token-Based Authentication:

Tokens: Objects that a user possesses for the purpose of user authentication

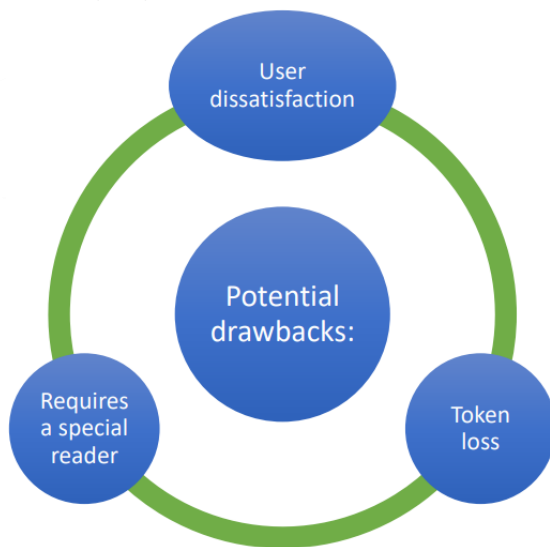
There are two types of tokens:

- memory cards
- smart cards

Memory Cards: can store but not process data.

The most common is the bank card with a magnetic stripe on the back. A magnetic stripe can store only a simple security code which can be read and reprogrammed by an inexpensive card reader. There are also memory cards that include an internal electronic memory.

They can be used alone for physical access or with some form of password or personal identification number (PIN).



Smart Cards:

Physical characteristics: include an embedded processor. A smart token that looks like a bank card is called a smart card. Smart tokens can look like calculators, keys, or other small portable objects.

Interface: manual interfaces include a keypad and display for human/token interaction. Smart tokens with an electronic interface communicate with a compatible reader/writer

Authentication protocol:

- static
- dynamic password generator
- challenge-response

Static Biometric Authentication: attempts to authenticate an individual based on his or her unique physical characteristics.

Includes static characteristics such as:

- fingerprints
- hand geometry
- facial characteristics
- retinal and iris patterns

Dynamic characteristics such as:

- voiceprint
- signature

Physical Characteristic:

Facial characteristics

- most common means of human-to-human identification
- examples: eyes, eyebrows, nose, lips, and chin shape
- alternative approach is to use an infrared camera to produce a face thermogram

Fingerprints

- pattern of ridges and furrows on the surface of the fingertip
- unique across the entire human population

Hand geometry

- identify features of the hand, including shape, and lengths and widths of fingers

Retinal pattern

- the pattern formed by veins beneath the retinal surface is unique
- a retinal biometric system obtains a digital image of the retinal pattern by projecting a low-intensity beam of visual or infrared light into the eye

Iris

- the detailed structure of the iris is unique

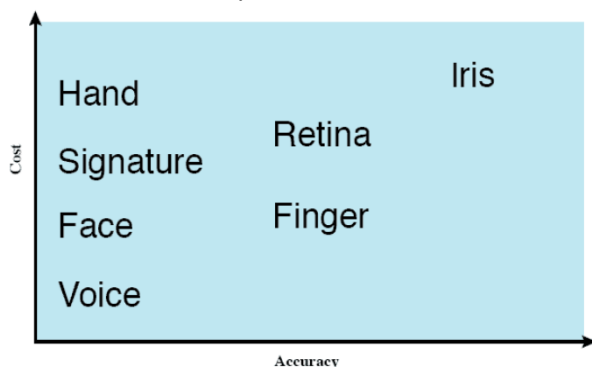
Signature

- each individual has a unique style of handwriting

Voice

- voice patterns are closely tied to the physical and anatomical characteristics of the speaker

Cost versus Accuracy:



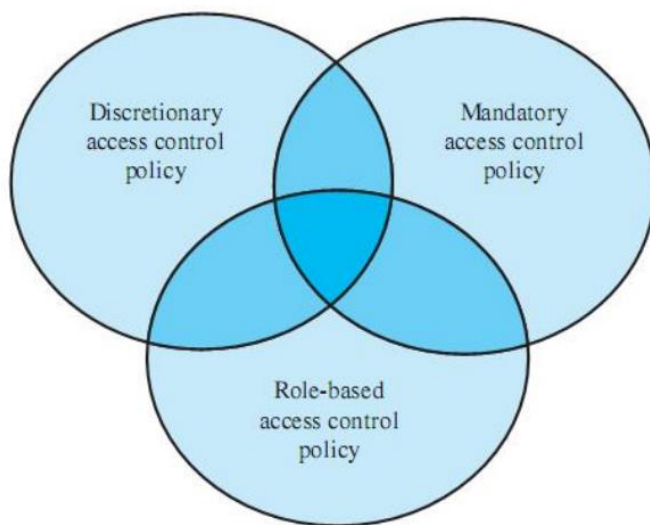
10.5 ACCESS CONTROL

Access Control: dictates what types of access are permitted, under what circumstances, and by whom

Access control policies are generally grouped into the following categories:

- Discretionary access control (DAC): controls access based on the identity of the requestor and on access rules stating what requestors are (or are not) allowed to do
- Mandatory access control (MAC): controls access based on comparing security labels with security clearances
- Role-based access control (RBAC): controls access based on the roles that users have within the system and on rules stating what accesses are allowed to users in given roles

Di queste tecniche se ne può usare anche più di una contemporaneamente:

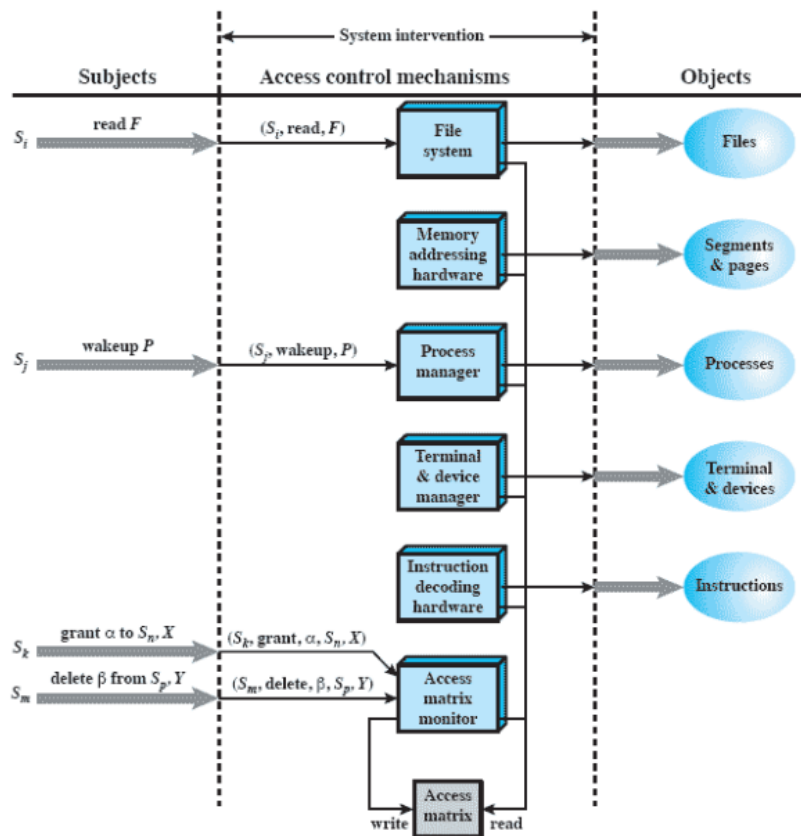


Extended Access Control Matrix:

		OBJECTS								
		subjects			files		processes		disk drives	
		S ₁	S ₂	S ₃	F ₁	F ₂	P ₁	P ₂	D ₁	D ₂
SUBJECTS	S ₁	control	owner	owner control	read *	read owner	wakeup	wakeup	seek	owner
	S ₂		control		write *	execute			owner	seek *
	S ₃			control		write	stop			

* - copy flag set

Organization of the Access Control Function:

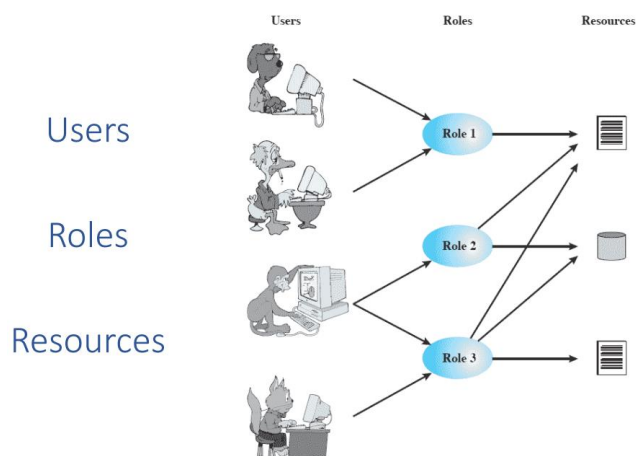


Role-Based Access Control:

Based on the roles that users assume in a system rather than the user's identity. Models define a role as a job function within an organization.

Systems assign access rights to roles instead of individual users; in turn, users are assigned to different roles, either statically or dynamically, according to their responsibilities.

NIST has issued a standard that requires support for access control and administration through roles.



Ci possono essere più utenti con lo stesso ruolo e ci può essere un utente con più ruoli.

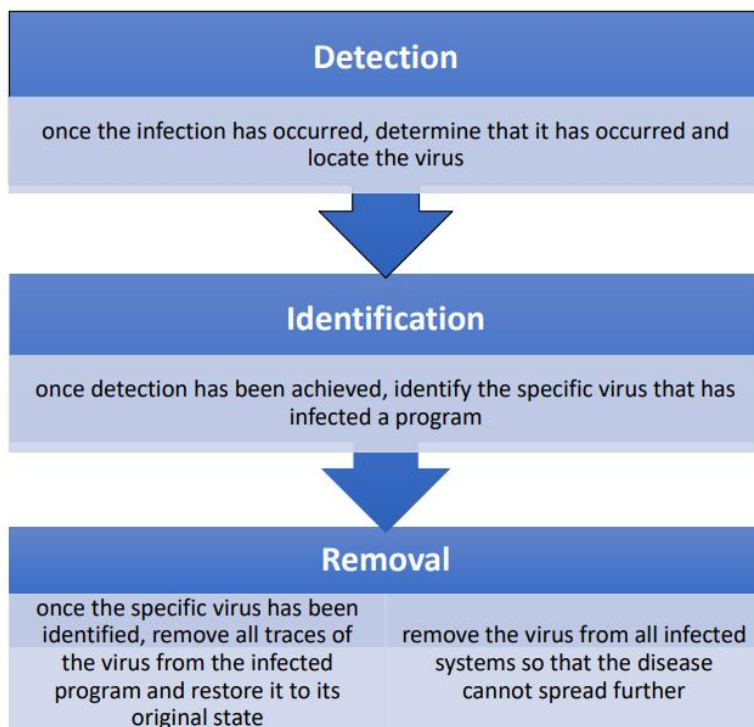
Access Control Matrix Representation of RBAC:

	R_1	R_2	$\bullet \bullet \bullet$	R_n
U_1	×			
U_2	×			
U_3		×		×
U_4				×
U_5				×
U_6				×
$\bullet$				
$\bullet$				
$\bullet$				
U_m	×			

	OBJECTS								
	R_1	R_2	R_n	F_1	F_1	P_1	P_2	D_1	D_2
R_1	control	owner	owner control	read *	read owner	wakeup	wakeup	seek	owner
R_2		control		write *	execute			owner	seek *
$\bullet$									
$\bullet$									
$\bullet$									
R_n			control		write	stop			

10.6 ANTIVIRUS

Antivirus Approaches:



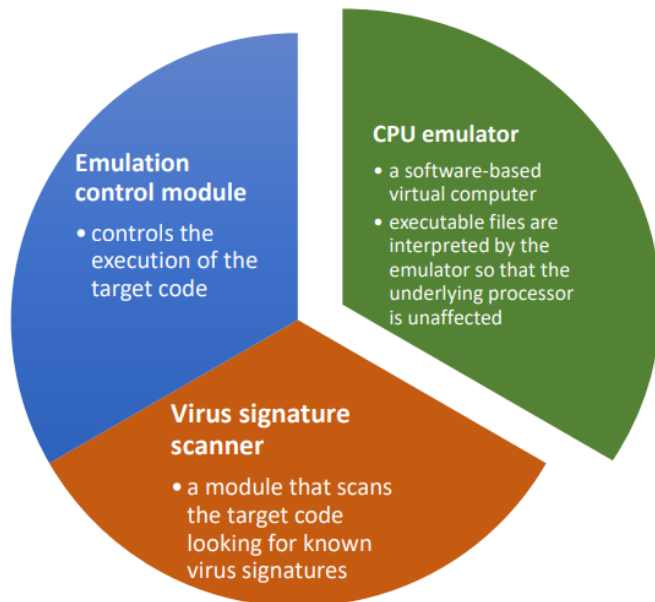
Ideal solution to the threat of viruses is prevention, don't allow a virus onto the system in the first place. That goal is, in general, impossible to achieve, although prevention can reduce the number of successful viral attacks.

If detection succeeds but either identification or removal is not possible, then the alternative is to discard the infected program and reload a clean backup version.

Generic Decryption (GD): enables the antivirus program to easily detect even the most complex polymorphic viruses while maintaining fast scanning speeds.

When a file containing a polymorphic virus is executed, the virus must decrypt itself to activate. Executable files are run through a GD scanner.

GD scanner contains:

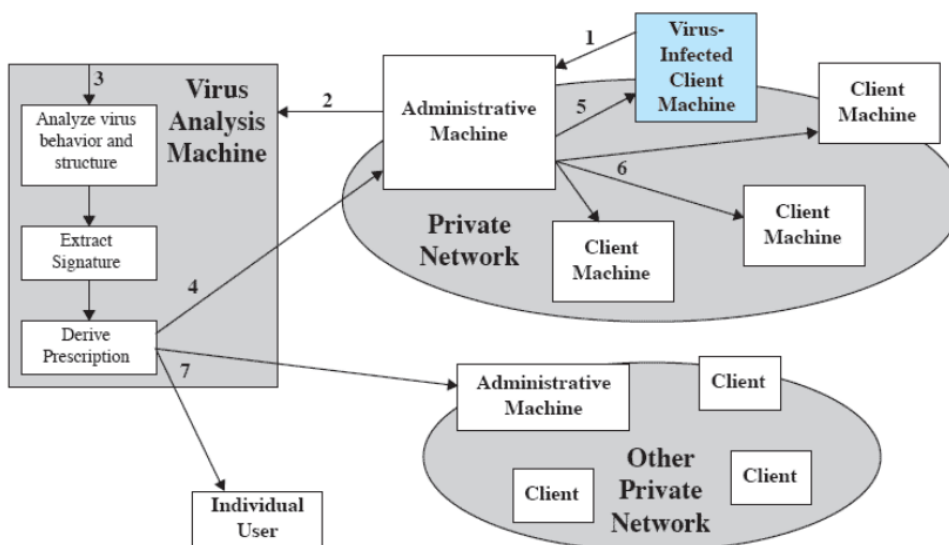


Most difficult design issue with a GD scanner is to determine how long to run each interpretation.

Digital Immune System: a comprehensive approach to virus protection developed by IBM and refined by Symantec. Motivation for development has been the rising threat of Internet-based virus propagation.

Two major trends in Internet technology have had an increasing impact on the rate of virus propagation in recent years: integrated mail systems and mobile-program systems.

Objective of the system is to provide rapid response time so that viruses can be stamped out almost as soon as they are introduced.



10.7 FIREWALLS

Vediamo ora Firewalls and Intrusion Prevention Systems.

Firewall: serve a proteggere una rete. Fa analisi dei pacchetti del traffico di rete. Decide se un pacchetto può proseguire o meno.

Mezzi efficaci per la protezione delle LAN. Internet connectivity is essential for organization and individuals, but creates a threat.

Could secure workstations and servers; also use firewall as perimeter defence (single choke point to impose security).

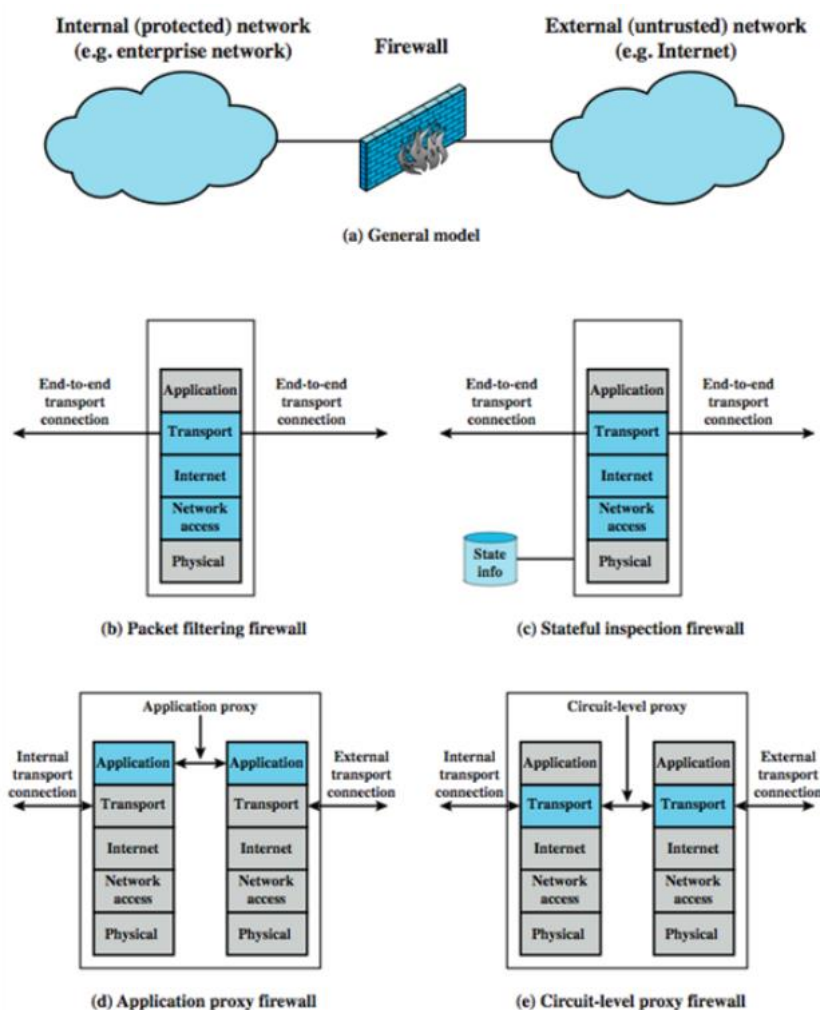
Firewall capabilities:

- defines a single choke point
- provides a location for monitoring security events
- convenient platform for some Internet functions such as NAT, usage monitoring, IPSEC VPNs

limitations:

- cannot protect against attacks bypassing firewall
- may not protect fully against internal threats
- improperly secure wireless LAN
- laptop, PDA, portable storage device infected outside then used inside

Types of Firewalls:



Packet Filtering Firewall:

applies rules to packets in/out of firewall. Based on information in packet header (src/dest IP addr & port, IP protocol, interface).

Typically a list of rules of matches on fields, if match rule says if forward or discard packet

Two default policies:

- discard, prohibit unless expressly permitted. More conservative, controlled, visible to users
- forward, permit unless expressly prohibited. Easier to manage/use but less secure

Packet Filter Rules: regole per determinare quali pacchetti possono passare nella rete. Essenzialmente le regole dicono “può passare tutto, tranne ...” oppure “non può passare nulla, tranne ...”.

Rule Set A

action	ourhost	port	theirhost	port	comment
block	*	*	SPIGOT	*	we don't trust these people
allow	OUR-GW	25	*	*	connection to our SMTP port

Rule Set B

action	ourhost	port	theirhost	port	comment
block	*	*	*	*	default

Rule Set C

action	ourhost	port	theirhost	port	comment
allow	*	*	*	25	connection to their SMTP port

Rule Set D

action	src	port	dest	port	flags	comment
allow	{our hosts}	*	*	25		our packets to their SMTP port
allow	*	25	*	*	ACK	their replies

Rule Set E

action	src	port	dest	port	flags	comment
allow	{our hosts}	*	*	*		our outgoing calls
allow	*	*	*	*	ACK	replies to our calls
allow	*	*	*	>1024		traffic to nonservers

Packet filter weaknesses:

- cannot prevent attack on application bugs
- limited logging functionality
- do not support advanced user authentication
- vulnerable to attacks on TCP/IP protocol bugs
- improper configuration can lead to breaches

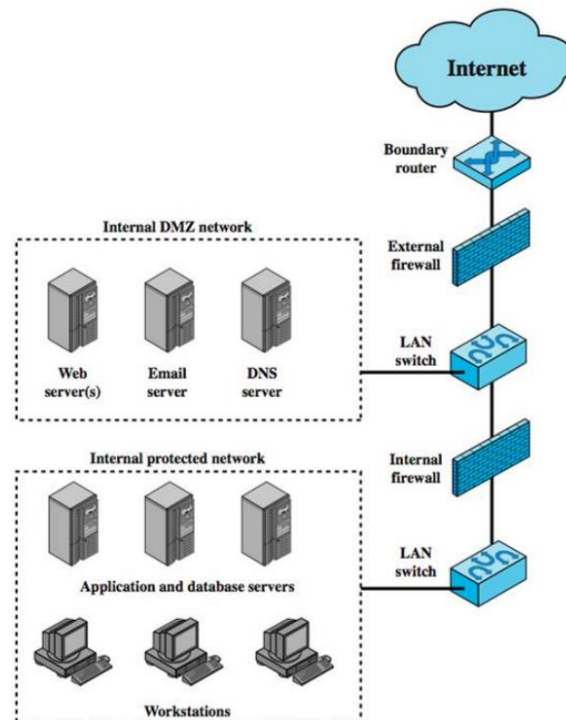
attacks:

- IP address spoofing, source route attacks, tiny fragment attacks

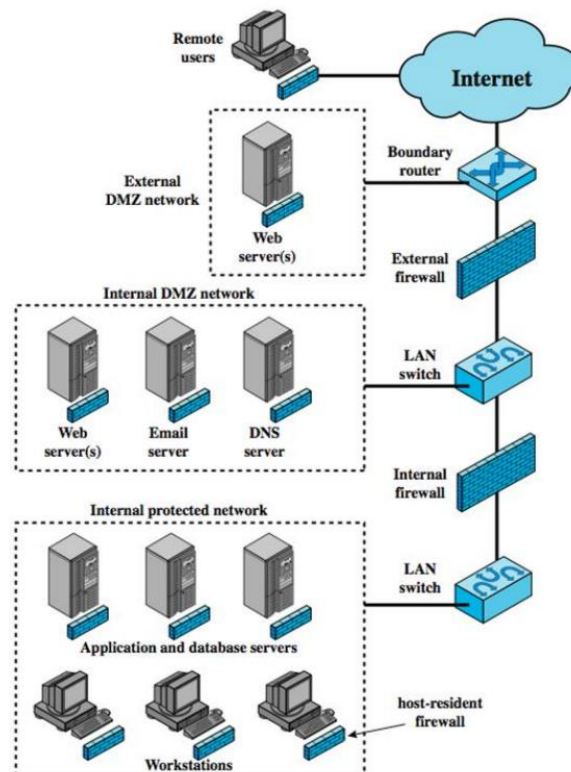
Stateful Inspection Firewall: reviews packet header information but also keeps info on TCP connections. Typically have low, “known” port number for server and high, dynamically assigned client port number. Simple packet filter must allow all return high port numbered packets back in, stateful inspection packet firewall tightens rules for TCP traffic using a directory of TCP connections. Only allow incoming traffic to high-numbered ports for packets matching an entry in this directory. May also track TCP seq numbers as well.

Other solutions: Application-level gateway (proxy); Circuit-level gateway; Socket-level gateway.

Firewall Locations:



Distributed Firewalls:



10.8 INTRUSION DETECTION

Si vuole identificare delle anomalie.

Significant issue hostile/unwanted trespass: from benign to serious

User trespass: unauthorized logon, privilege abuse

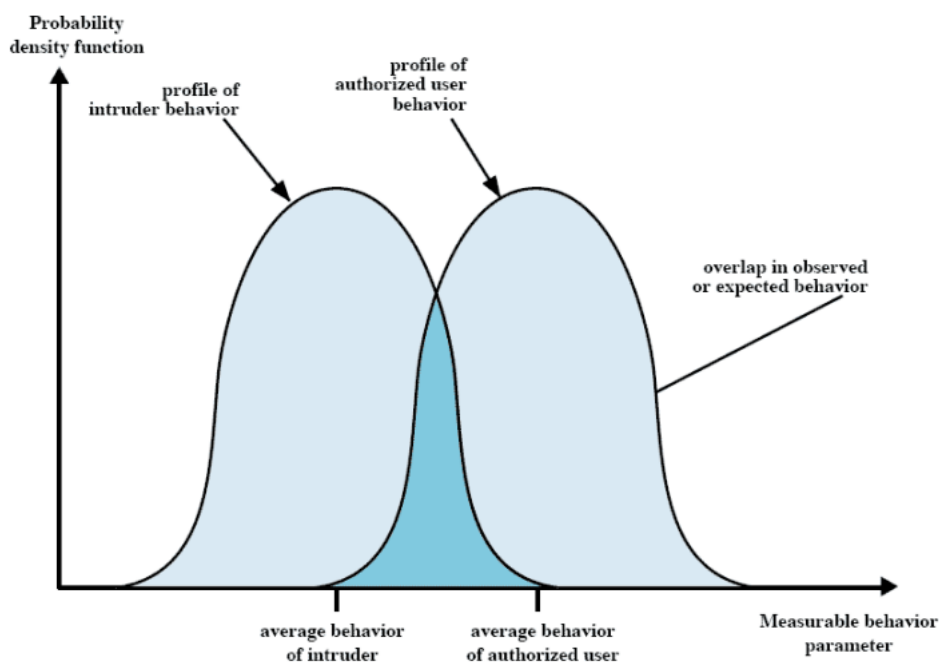
Software trespass: virus, worm, or trojan horse

Classes of **intruders**: Hackers, masquerader, APTs

Basic principles:

- Intrusion detection is based on the assumption that the behavior of the intruder differs from that of a legitimate user in ways that can be quantified
- If an intrusion is detected quickly enough, the intruder can be identified and ejected from the system before any damage is done or any data are compromised
- An effective IDS can serve as a deterrent, thus acting to prevent intrusions
- Intrusion detection enables the collection of information about intrusion techniques that can be used to strengthen intrusion prevention measures

Profiles of Behavior of intruders and authorized users:



Host-Based Intrusion Detection System (IDS):

Monitors activity on the system in a variety of ways to detect suspicious behavior. Primary purpose is to detect intrusions, log suspicious events, and send alerts.

Can detect both external and internal intrusions.

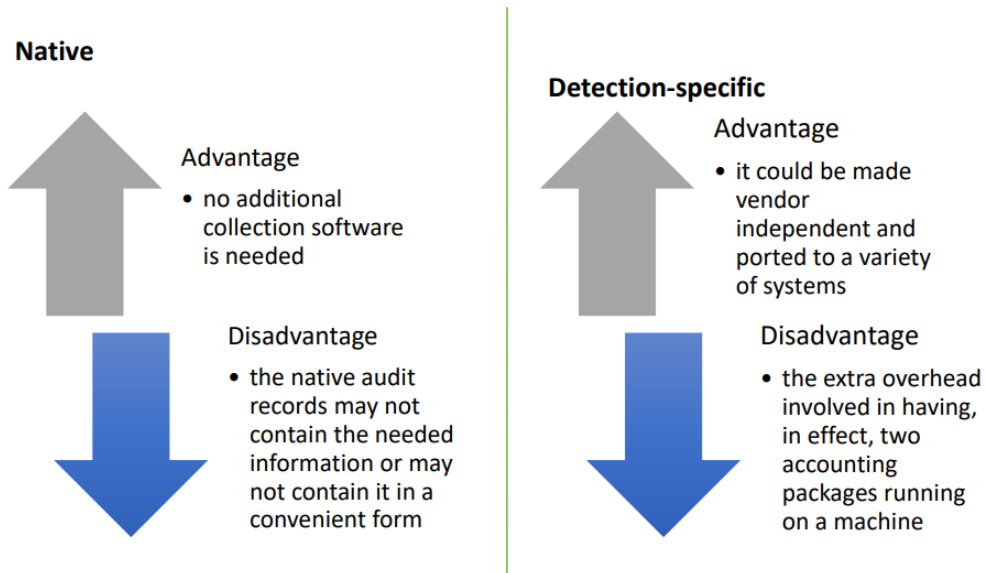
Anomaly detection:

- collection of data relating to behavior of legitimate users over time
- threshold detection
- profile based detection

Signature detection:

- define a set of rules or attack patterns that can be used to decide that a given behavior is that of an intruder

Audit Records:



Anomaly Detection:

Threshold detection: checks excessive event occurrences over time. Alone a crude and ineffective intruder detector, must determine both thresholds and time intervals.

Profile based: characterize past behavior of users/groups, then detect significant deviations based on analysis of audit records.

Gather metrics: counter, gauge, interval timer, resource utilization.

Analyze: mean and standard deviation, multivariate, markov process, time series, operational model

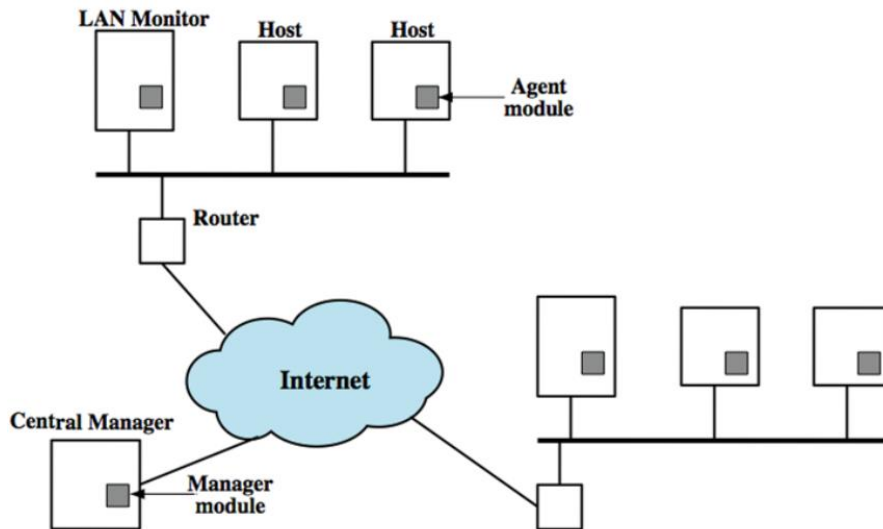
Signature Detection:

observe events on system and applying a set of rules to decide if intruder

Approaches:

- rule-based anomaly detection: analyze historical audit records for expected behavior, then match with current behavior
- rule-based penetration identification: rules identify known penetrations/weaknesses, often by analyzing attack scripts from Internet. Supplemented with rules from security experts
- Artificial Intelligence

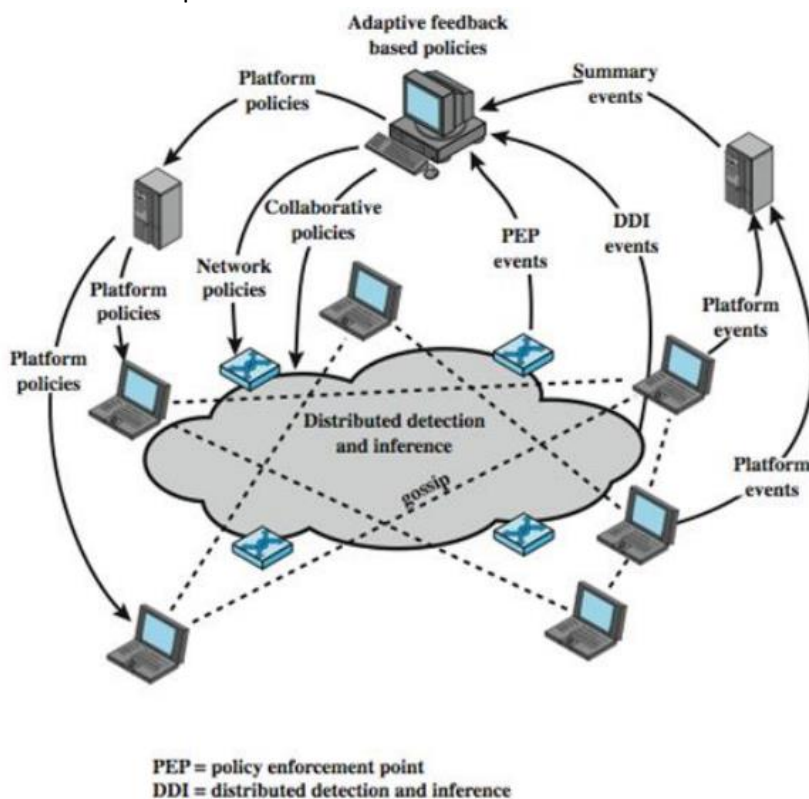
Distributed Host-Based IDS



Intrusion Detection Techniques:

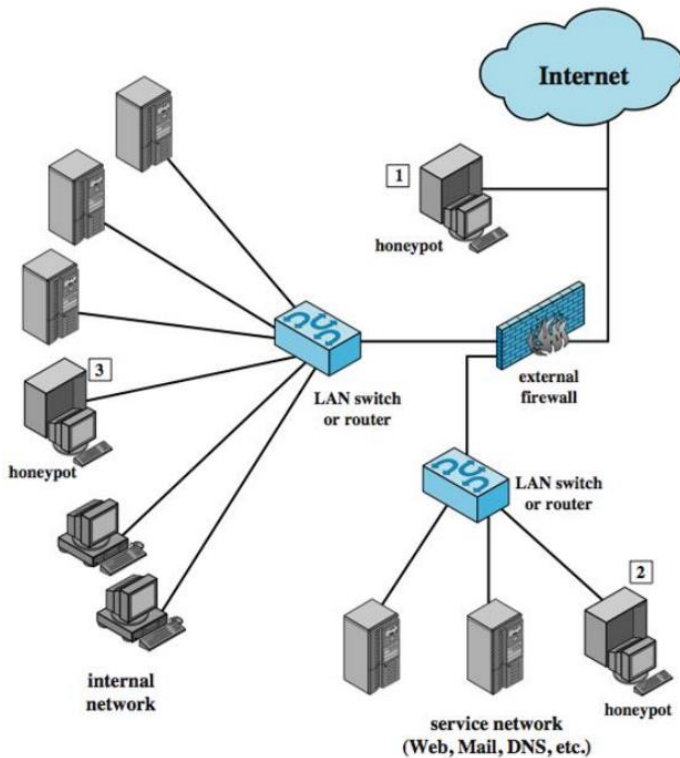
- signature detection: at application, transport, network layers; unexpected application services, policy violations
- anomaly detection: of denial of service attacks, scanning, worms
- when potential violation detected sensor sends an alert and logs information. Used by analysis module to refine intrusion detection parameters and algorithms. Used by security admin to improve protection.

Distributed Adaptive Intrusion Detection:



Honeypots: are decoy systems, filled with fabricated info instrumented with monitors / event loggers. Divert and hold attacker to collect activity info without exposing production systems. Initially were single systems, more recently are/emulate entire networks.

Honeypot Deployment:



10.9 SOFTWARE QUALITY VS SECURITY

Software quality and reliability (in general): accidental failure of program, from theoretically random unanticipated input. Improve using structured design and testing. Not how many bugs, but how often triggered

Software security is related, but attacker chooses input distribution, specifically targeting buggy code to exploit. Triggered by often very unlikely inputs, which common tests don't identify.

Da slide 151, fino a fine slide...